

(a) Modelo de encuesta integral MITRE D3FEND

1. Introducción y contexto

Esta encuesta tiene como finalidad cartografiar, con un mínimo de elegancia y un máximo de honestidad, el grado de adopción de MITRE D3FEND y de las métricas asociadas a la defensa informada por amenazas en su organización.

Se dirige a responsables de ciberseguridad, tecnología, continuidad de negocio, gestión de riesgos y, en general, a cualquier alma valiente a la que se le haya encargado "que esto de los ciberataques no nos estalle en las manos".

2. Datos generales de la organización

2.1. Identificación básica

1. Nombre de la organización:
2. Sector principal de actividad (según clasificación NIS2 / legislación nacional):
3. Energía
4. Transporte
5. Salud
6. Agua potable y aguas residuales
7. Infraestructuras digitales / TIC
8. Banca y servicios financieros
9. Administración pública
10. Industria manufacturera crítica
11. Otros (especificar)
12. Tamaño aproximado de la organización (empleados):
13. Menos de 50
14. 50-249
15. 250-999
16. 1.000-4.999
17. 5.000 o más
18. Ámbito principal de operación:
19. Local / regional
20. Nacional
21. Multinacional dentro de la UE
22. Multinacional global

2.2. Rol de la persona que responde

- 23. Cargo principal:
- 24. CISO / Director de Seguridad de la Información
- 25. CIO / Director de Tecnología
- 26. Responsable de SOC / CSIRT interno
- 27. Responsable de Continuidad de Negocio / Resiliencia
- 28. Responsable de Riesgos / Cumplimiento
- 29. Otro (especificar)
- 30. Antigüedad aproximada en el rol actual:
- 31. Menos de 1 año
- 32. 1–3 años
- 33. 3–7 años
- 34. Más de 7 años

3. Conocimiento y adopción de MITRE D3FEND

3.1. Nivel de conocimiento

- 35. ¿Cuál es el nivel de conocimiento general de MITRE D3FEND en su organización?
- 36. Nunca lo he oído mencionar
- 37. Me suena vagamente, pero no se utiliza
- 38. Lo conocen algunas personas clave (p.ej., ingeniería de detecciones, arquitectura de seguridad)
- 39. Está integrado en algunos procesos o herramientas, aunque sin estandarizar
- 40.
Forma parte explícita de nuestra metodología y documentación de seguridad
- 41.
En relación con MITRE ATT&CK, ¿cómo describiría la situación en su organización?
- 42. No utilizamos MITRE ATT&CK
- 43. Se utiliza de forma puntual para análisis o presentaciones
- 44. Está integrado en procesos de threat intel / ingeniería de detección
- 45. Se utiliza sistemáticamente en SOC, red team o arquitectura
- 46. ATT&CK está alineado con nuestros controles y roadmap de seguridad

Forma parte explícita de nuestra metodología y documentación de seguridad

En relación con MITRE ATT&CK, ¿cómo describiría la situación en su organización?

3.2. Uso de D3FEND en la práctica

47. ¿Se utiliza explícitamente MITRE D3FEND para describir controles o contramedidas en su organización?

48. No, no se utiliza

49. Se utiliza de forma experimental o en pilotos

50. Se utiliza sólo en ciertos proyectos o dominios (p.ej., cloud, endpoint)

51. Se utiliza de manera consistente en varios dominios

52.

Es el lenguaje de referencia para describir controles y coberturas

53.

¿En qué ámbitos se hace referencia a D3FEND (puede seleccionar varios)?

54. Arquitectura de seguridad

55. Ingeniería de detecciones / reglas de SIEM

56. Diseño de playbooks de respuesta

57. Análisis de brechas frente a ATT&CK

58. OT / ICS / sistemas industriales

59. Relación con proveedores / RFPs

60.

No se hace referencia

61.

¿La organización utiliza el conocimiento de D3FEND para discutir inversiones en seguridad (p.ej., priorización de herramientas o proyectos)?

62. Nunca

63. Ocasionalmente, de manera informal

64. En algunos casos, para justificar decisiones concretas

65. De forma habitual, como marco de referencia

66. Está incorporado en el proceso formal de planificación y presupuesto

Es el lenguaje de referencia para describir controles y coberturas

¿En qué ámbitos se hace referencia a D3FEND (puede seleccionar varios)?

No se hace referencia

¿La organización utiliza el conocimiento de D3FEND para discutir inversiones en seguridad (p.ej., priorización de herramientas o proyectos)?

4. Modelado con D3FEND CAD y grafos de contramedidas

4.1. Uso de D3FEND CAD

67. ¿Conoce o utiliza su organización la herramienta D3FEND CAD para modelar escenarios y arquitecturas defensivas?

68. Desconocemos la existencia de D3FEND CAD

69. Conocemos la herramienta, pero no la utilizamos

70. Se ha probado en algún caso aislado o laboratorio

71. Se utiliza de manera limitada para algunos sistemas o proyectos

72.

Se utiliza sistemáticamente para modelar arquitecturas de seguridad y escenarios de ataque/defensa

73.

En caso de uso, ¿para qué finalidades se ha empleado D3FEND CAD?

74. Documentar arquitecturas defensivas de referencia

75. Analizar coberturas frente a ATT&CK

76. Diseñar y ensayar playbooks de respuesta

77. Modelar escenarios de ransomware / ataques dirigidos

78. Modelar sistemas OT / ICS

79. Formación interna y comunicación con otras áreas

80. No aplicable / no se utiliza

Se utiliza sistemáticamente para modelar arquitecturas de seguridad y escenarios de ataque/defensa

En caso de uso, ¿para qué finalidades se ha empleado D3FEND CAD?

4.2. Calidad y alcance del modelado

81. ¿En qué medida considera que los modelos (con D3FEND CAD u otras herramientas) reflejan de manera fiel la realidad de sus sistemas?

82. Son meros dibujos bonitos para presentaciones

83. Reflejan parcialmente la realidad, con simplificaciones significativas

84. Recogen adecuadamente los componentes críticos, pero no todo el detalle

85. Son representaciones suficientemente fieles para extraer métricas fiables

86.

Se actualizan de forma continua y están integrados con inventarios y CMDB

87.

¿Qué porcentaje aproximado de activos críticos (según su propia definición de criticidad) está representado en modelos formales de contramedidas?

88. 0–20 %

89. 21–40 %

90. 41–60 %

91. 61–80 %

92. 81–100 %

93. Desconozco el dato / preferiría no responder

Se actualizan de forma continua y están integrados con inventarios y CMDB

¿Qué porcentaje aproximado de activos críticos (según su propia definición de criticidad) está representado en modelos formales de contramedidas?

5. Indicadores de cobertura ATT&CK-D3FEND

5.1. Definición de catálogos de amenazas

94. ¿Dispone su organización de un catálogo explícito de técnicas ATT&CK consideradas prioritarias?

95. No existe tal catálogo

96. Existe de forma informal (listas dispersas, documentos no consolidados)

97. Existe un catálogo definido para algunos dominios/sistemas

98. Existe un catálogo definido a nivel organizativo

99.

El catálogo está alineado con amenazas sectoriales y se revisa periódicamente

100.

¿Con qué frecuencia se revisa ese catálogo de técnicas ATT&CK prioritarias?

101. Nunca / no se revisa

102. Cada más de 2 años

103. Anualmente

104. Semestralmente

105. Trimestralmente o con mayor frecuencia

El catálogo está alineado con amenazas sectoriales y se revisa periódicamente

¿Con qué frecuencia se revisa ese catálogo de técnicas ATT&CK prioritarias?

5.2. Medición de coberturas

106. ¿Miden de forma sistemática qué técnicas ATT&CK cuentan con al menos una contramedida D3FEND implementada?

107. No, no realizamos ese tipo de medición

108. Sí, pero sólo para algunos sistemas o proyectos

109. Sí, para los activos críticos

110.

Sí, de forma sistemática a nivel organizativo

111.

¿Cómo describiría el nivel actual de cobertura de técnicas ATT&CK críticas con contramedidas adecuadas?

112. Mayoritariamente desconocido

113. Parcial y con lagunas importantes

114. Razonable, aunque con brechas conocidas pendientes de abordar

115. Alto, con un inventario claro de las pocas lagunas restantes

116.

Medido y gestionado como objetivo explícito en los planes de seguridad

117.

Indique, de forma aproximada, qué porcentaje de las técnicas ATT&CK críticas identificadas considera usted que tiene al menos una contramedida efectiva implementada:

118. 0–25 %

119. 26–50 %

120. 51–75 %

121. 76–90 %

122. Más del 90 %

123.

No se dispone de esta estimación

124.

¿Utilizan mapas de calor, dashboards u otras visualizaciones para representar coberturas ATT&CK–D3FEND?

125. No, trabajamos básicamente con documentos y hojas de cálculo

126. Sí, pero desarrollados de forma ad hoc sin estandarización

127. Sí, mediante dashboards consolidados a nivel de SOC u oficina de ciberseguridad

128. Sí, con cuadros de mando ejecutivos que se revisan en comités de dirección

Sí, de forma sistemática a nivel organizativo

¿Cómo describiría el nivel actual de cobertura de técnicas ATT&CK críticas con contramedidas adecuadas?

Medido y gestionado como objetivo explícito en los planes de seguridad

Indique, de forma aproximada, qué porcentaje de las técnicas ATT&CK críticas identificadas considera usted que tiene al menos una contramedida efectiva implementada:

No se dispone de esta estimación

¿Utilizan mapas de calor, dashboards u otras visualizaciones para representar coberturas ATT&CK-D3FEND?

6. Métricas operativas (latencia, eficacia, telemetría)

6.1. Latencia de detección y respuesta

129. ¿Miden de forma sistemática la latencia de detección (tiempo desde el evento hasta su detección como incidente)?

130. No se mide

131. Se mide de forma puntual para ciertos incidentes

132. Se mide para los incidentes de alta criticidad

133.

Se mide de forma sistemática para todos los incidentes gestionados

134.

Para incidentes críticos, ¿en qué franja se sitúa habitualmente el tiempo medio de detección (MTTD) reportado?

135. Menos de 5 minutos

136. Entre 5 y 30 minutos

137. Entre 30 minutos y 4 horas

138. Entre 4 y 24 horas

139. Más de 24 horas

140.

No se dispone de este dato

141.

¿Miden el tiempo hasta la mitigación o contención efectiva (MTTM/MTTR) de incidentes críticos?

142. No se mide

143. Se mide de forma ad hoc en post-mortems

144. Se mide para incidentes críticos de forma sistemática

145. Se mide y se establecen objetivos explícitos (SLOs) de mejora

Se mide de forma sistemática para todos los incidentes gestionados

Para incidentes críticos, ¿en qué franja se sitúa habitualmente el tiempo medio de detección (MTTD) reportado?

No se dispone de este dato

¿Miden el tiempo hasta la mitigación o contención efectiva (MTTM/MTTR) de incidentes críticos?

6.2. Eficacia de mitigaciones

146. ¿Calculan la tasa de éxito de las mitigaciones (es decir, qué proporción de intentos de mitigación logra realmente neutralizar la amenaza)?

147. No, ese indicador no se calcula

148. Se estima cualitativamente en algunos análisis

149. Se calcula cuantitativamente para incidentes críticos

150.

Se calcula y se reporta de forma periódica

151.

¿Disponen de métricas sobre la recurrencia de incidentes de tipo similar tras supuestas mitigaciones?

152. No

153. Sí, de manera informal o ad hoc

154. Sí, mediante indicadores sistemáticos de recurrencia

Se calcula y se reporta de forma periódica

¿Disponen de métricas sobre la recurrencia de incidentes de tipo similar tras supuestas mitigaciones?

6.3. Telemetría y cobertura de sensores

155. ¿Se cuantifica qué porcentaje de activos o flujos relevantes está instrumentado con telemetría adecuada (sensores, logs, sondas, etc.)?

156. No se cuantifica

157. Se cuantifica para algunos sistemas o entornos

158. Se cuantifica para activos críticos

159.

Se cuantifica de forma sistemática a nivel de organización

160.

¿Cómo describiría la calidad de la telemetría disponible para soportar las técnicas defensivas modeladas (por ejemplo, según D3FEND)?

161. Fragmentaria y poco fiable

162. Aceptable, pero con lagunas significativas

163. Buena, aunque mejorable

164.

Alta, suficiente para análisis avanzados y automatización

165.

¿Se analizan y reportan tasas de falsos positivos y falsos negativos en las detecciones clave?

166. No

167. Sí, pero sólo de forma puntual

168. Sí, como parte de un proceso de mejora continua del SOC

Se cuantifica de forma sistemática a nivel de organización

¿Cómo describiría la calidad de la telemetría disponible para soportar las técnicas defensivas modeladas (por ejemplo, según D3FEND)?

Alta, suficiente para análisis avanzados y automatización

¿Se analizan y reportan tasas de falsos positivos y falsos negativos en las detecciones clave?

7. Entornos OT / ICS y extensión D3FEND para OT

169. ¿Opera su organización infraestructuras OT / ICS o sistemas ciberfísicos críticos?

170. No

171. Sí, pero con peso limitado en la operación

172.

Sí, constituyen una parte significativa de la operación

173.

En caso afirmativo, ¿se han modelado explícitamente contramedidas para entornos OT utilizando D3FEND u otros marcos equivalentes?

174. No se han modelado

175. Se han modelado parcialmente, de forma piloto

176. Se han modelado para activos OT críticos

177.

Se ha realizado un modelado amplio y sistemático

178.

¿Se dispone de métricas específicas para OT, tales como porcentaje de rutas de mando y control cubiertas, cobertura de monitorización de protocolos industriales o tiempo de recuperación de funciones OT críticas?

179. No se dispone de métricas específicas

180. Se dispone de algunas métricas básicas

181. Se dispone de un conjunto definido y revisado de métricas OT

Sí, constituyen una parte significativa de la operación

En caso afirmativo, ¿se han modelado explícitamente contramedidas para entornos OT utilizando D3FEND u otros marcos equivalentes?

Se ha realizado un modelado amplio y sistemático

¿Se dispone de métricas específicas para OT, tales como porcentaje de rutas de mando y control cubiertas, cobertura de monitorización de protocolos industriales o tiempo de recuperación de funciones OT críticas?

8. Integración con cumplimiento normativo y regulación

182. ¿Cómo describiría el grado de integración entre las prácticas de seguridad basadas en ATT&CK/D3FEND y las obligaciones normativas (NIS2, legislación nacional, sectorial, etc.)?
183. Son mundos separados que se toleran a distancia
184. Hay conexiones informales entre ambos mundos
185. Se procura alinear controles técnicos con requisitos normativos
186. Existe un mapeo explícito entre controles/técnicas y requisitos normativos
187. ¿Se ha realizado un mapeo formal entre D3FEND y marcos de control como NIST 800-53, ISO 27001 o políticas internas?
188. No
189. Sí, parcialmente (para algunos dominios)
190. Sí, de forma amplia y documentada
191. ¿Utilizan métricas derivadas de D3FEND (cobertura, latencia, eficacia, telemetría) como evidencia en auditorías o procesos de supervisión?
192. No
193. En ocasiones, de manera complementaria
194. De forma habitual, como evidencia principal
- Existe un mapeo explícito entre controles/técnicas y requisitos normativos
- ¿Se ha realizado un mapeo formal entre D3FEND y marcos de control como NIST 800-53, ISO 27001 o políticas internas?
- Sí, de forma amplia y documentada
- ¿Utilizan métricas derivadas de D3FEND (cobertura, latencia, eficacia, telemetría) como evidencia en auditorías o procesos de supervisión?

9. Métricas de negocio, IGM y ROI de seguridad

195. ¿Se traduce el estado de coberturas y métricas de seguridad en indicadores de riesgo para la alta dirección (p.ej., riesgo residual frente a escenarios de referencia)?

196. No, la alta dirección recibe información básicamente cualitativa

197. Sí, con indicadores mayoritariamente cualitativos y algunos cuantitativos

198.

Sí, con indicadores cuantitativos alineados con apetito y tolerancia al riesgo

199.

¿Se evalúa de manera estructurada el impacto económico de incidentes (pérdidas directas, costes de recuperación, impacto reputacional aproximado, etc.)?

200. No

201. Sí, de forma puntual en grandes incidentes

202.

Sí, mediante un marco de análisis económico y actuarial definido

203.

¿Se calculan indicadores de madurez global (IGM) de la capacidad defensiva, basados en métricas de cobertura y eficacia?

204. No

205. Sí, pero con metodologías ad hoc

206.

Sí, con un modelo formalizado y revisado periódicamente

207.

¿Se evalúa el retorno de la inversión (ROI) de proyectos o herramientas de seguridad utilizando métricas derivadas de ATT&CK/D3FEND (por ejemplo, reducción de tiempo de detección, de superficies no cubiertas o de frecuencia de incidentes)?

208. No

209. De forma episódica, cuando hay que defender un presupuesto

210. De manera sistemática, en el ciclo de vida de inversiones en seguridad

Sí, con indicadores cuantitativos alineados con apetito y tolerancia al riesgo

¿Se evalúa de manera estructurada el impacto económico de incidentes (pérdidas directas, costes de recuperación, impacto reputacional aproximado, etc.)?

Sí, mediante un marco de análisis económico y actuarial definido

¿Se calculan indicadores de madurez global (IGM) de la capacidad defensiva, basados en métricas de cobertura y eficacia?

Sí, con un modelo formalizado y revisado periódicamente

¿Se evalúa el retorno de la inversión (ROI) de proyectos o herramientas de seguridad utilizando métricas derivadas de ATT&CK/D3FEND (por ejemplo, reducción de tiempo de detección, de superficies no cubiertas o de frecuencia de incidentes)?

10. Gobierno, cultura y talento

211. ¿Qué órganos de gobierno revisan regularmente los indicadores de seguridad basados en coberturas y métricas operativas?

212. Ninguno, se revisan de manera informal

213. Comité de seguridad / continuidad

214. Comité de riesgos

215. Comité de dirección

216.

Consejo de administración

217.

¿Con qué frecuencia se revisan formalmente estos indicadores en órganos de gobierno?

218. Menos de una vez al año

219. Anualmente

220. Trimestralmente

221.

Mensualmente o con mayor frecuencia

222.

¿Dispone de perfiles internos con conocimiento específico de MITRE ATT&CK y D3FEND (ingeniería de detecciones, arquitectos de seguridad, analistas de riesgo técnico)?

223. No

224. Sí, uno o dos perfiles clave

225.

Sí, un equipo dedicado o comunidad de práctica

226.

¿Se incluye la formación en ATT&CK/D3FEND en los planes de capacitación interna?

227. No

228. Sí, de forma puntual

229. Sí, de forma estructurada y periódica

Consejo de administración

¿Con qué frecuencia se revisan formalmente estos indicadores en órganos de gobierno?

Mensualmente o con mayor frecuencia

¿Dispone de perfiles internos con conocimiento específico de MITRE ATT&CK y D3FEND (ingeniería de detecciones, arquitectos de seguridad, analistas de riesgo técnico)?

Sí, un equipo dedicado o comunidad de práctica

¿Se incluye la formación en ATT&CK/D3FEND en los planes de capacitación interna?

11. Perspectiva y próximos pasos

230. ¿Qué barreras principales percibe para una adopción más amplia y rigurosa de D3FEND en su organización?

231. Falta de conocimiento interno

232. Falta de tiempo y recursos

233. Falta de herramientas que integren D3FEND de forma nativa

234. Complejidad percibida / curva de aprendizaje

235. Falta de presión regulatoria o de mercado

236.

Otras (especificar)

237.

En un mundo ideal (o al menos moderadamente razonable), ¿cuál sería el primer paso realista que su organización podría dar en los próximos 12 meses para mejorar en este ámbito?

238. Definir un catálogo de técnicas ATT&CK prioritarias

239. Mapear controles existentes a D3FEND

240. Empezar a utilizar D3FEND CAD en un sistema piloto

241. Definir y acordar 3–5 métricas clave de cobertura y eficacia

242. Integrar estas métricas en un cuadro de mando ejecutivo

243.

Incluir formación específica en el plan de capacitación

244.

Comentarios adicionales, confesiones tardías o deseos para el futuro próximo (respuesta abierta):

Otras (especificar)

En un mundo ideal (o al menos moderadamente razonable), ¿cuál sería el primer paso realista que su organización podría dar en los próximos 12 meses para mejorar en este ámbito?

Incluir formación específica en el plan de capacitación

Comentarios adicionales, confesiones tardías o deseos para el futuro próximo (respuesta abierta):

Gracias por el tiempo, la honestidad y, sobre todo, por seguir intentándolo en un mundo estadísticamente diseñado para hacerle la vida imposible al CISO.